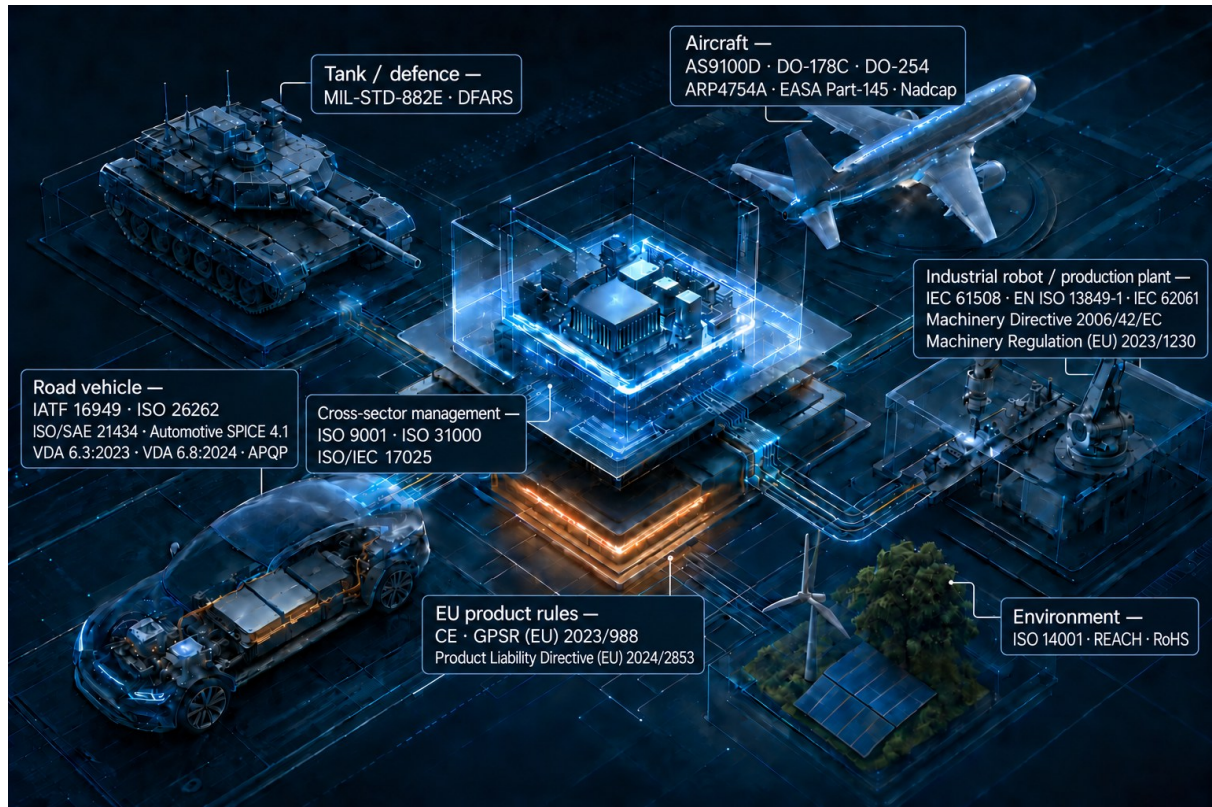


Normen, regulatorische Vorgaben und Qualitätsmanagement in hoch regulierten Industrien



Bernhard Wagner | Diplom-Informatiker, MBA

Automotive | Luftfahrt | Industrie | Verteidigung

1 Einleitung

Unternehmen in stark regulierten Industrien müssen nicht nur technisch leistungsfähige Produkte herstellen. Sie müssen zugleich nachweisen, dass Entwicklung, Fertigung, Lieferkette, Dokumentation und Freigabeprozesse die jeweils geltenden gesetzlichen, normativen und vertraglichen Anforderungen erfüllen.

Diese Analyse auf dem Stand vom 6. September 2026 verdeutlicht damit die Notwendigkeit eines integrierten Qualitäts- und Compliance-Management-Systems, das gemeinsame Prozesse einheitlich steuert und zugleich die branchen- und produktspezifischen Nachweise sicherstellt.

Anwendungs- und Haftungshinweis: Dieses Whitepaper dient der fachlichen Orientierung. Es ersetzt weder die Prüfung des konkreten Anwendungsbereichs und der verbindlichen Originaltexte noch eine individuelle Rechts- oder Zertifizierungsberatung.

2 Analyse der Normen und Regelwerke

Die betrachteten Regelwerke decken Qualitätsmanagement, Labor- und Prüfkompetenz, funktionale Sicherheit, Luftfahrtzulassung und -instandhaltung, kritische Sonderprozesse, US-amerikanische Verteidigungsaufträge, Umweltmanagement und europäisches Produktrecht ab. Sie unterscheiden sich in Rechtswirkung, Anwendungsbereich und Nachweislogik. Verstöße können unter anderem Lieferstopps, Rückrufe, Zulassungsverzögerungen, Vertragsverluste, behördliche Maßnahmen und Haftungsrisiken auslösen.

2.1 Automotive und automobile Lieferkette

2.1.1 IATF 16949:2016



Kernfokus: Die IATF 16949 übernimmt die Anforderungen der ISO 9001:2015 und ergänzt sie um automobilspezifische Anforderungen an das Qualitätsmanagement. Im Mittelpunkt stehen insbesondere Fehlervermeidung, robuste Entwicklungs- und Fertigungsprozesse, kontinuierliche Verbesserung sowie die Einhaltung kundenspezifischer Anforderungen¹.

Bedeutung: Die Norm ist für die Entwicklung und Serienfertigung von Steuerungs- und Leistungselektronik, elektrischen Antriebssystemen und Energiespeicherlösungen relevant. Wichtige Nachweise sind unter anderem APQP, FMEA, Control Plan, PPAP, MSA, SPC und 8D-Berichte.

Konkretes Risiko bei Verletzung: Werden kritische Produkt- oder Prozessmerkmale nicht ausreichend überwacht, können fehlerhafte Produkte ausgeliefert werden. Mögliche Folgen sind Lieferstopps, Rückrufe, Regressforderungen und der Verlust der Zertifizierung. Eine IATF-Zertifizierung ist häufig eine kunden- beziehungsweise OEM-spezifische Voraussetzung für die Aufnahme und den Verbleib im Lieferantenstamm; die konkrete Verpflichtung ist im Einzelfall zu prüfen.

2.1.2 ISO 26262



Kernfokus: Die ISO 26262 behandelt die funktionale Sicherheit elektrischer

¹ Frei nach <https://www.mobile2b.com/audits-inspections/iatf-16949>

und elektronischer Systeme in Straßenfahrzeugen. Sie umfasst den gesamten Sicherheitslebenszyklus von der Gefährdungsanalyse bis zur Entwicklung, Produktion und Außerbetriebnahme.

Bedeutung: Für sicherheitsrelevante Steuergeräte, Inverter, Antriebssysteme und Energiespeicher müssen Sicherheitsziele, ASIL-Einstufungen, Sicherheitsanforderungen und Verifikationsnachweise erstellt werden.

Konkretes Risiko bei Verletzung: Eine fehlerhafte Sicherheitsbewertung kann dazu führen, dass erforderliche Sicherheitsmechanismen fehlen. Daraus können Unfälle, Personenschäden, Rückrufe, Produkthaftungsansprüche und der Verlust der Kundenfreigabe entstehen.

2.1.3 ISO/SAE 21434:2021



Kernfokus: Cybersecurity-Engineering für elektrische und elektronische Systeme von Straßenfahrzeugen über den gesamten Produktlebenszyklus.

Damit steht der Schutz der Fahrzeugfunktionen und -daten vor unbefugten Eingriffen im Mittelpunkt.

Bedeutung: Die Norm fordert die systematische Identifikation, Bewertung und Behandlung von Cybersecurity-Risiken. Sie verbindet organisatorische Vorgaben mit Anforderungen an Entwicklung, Produktion, Betrieb, Wartung und Außerbetriebnahme und ergänzt die funktionale Sicherheit nach ISO 26262.

Konkretes Risiko bei Verletzung: Unentdeckte Schwachstellen können Manipulationen von Fahrzeugfunktionen, unbefugte Zugriffe auf Fahrzeugdaten oder den Ausfall sicherheitsrelevanter Systeme ermöglichen. Zusätzlich drohen die Ablehnung durch Fahrzeughersteller, fehlende Nachweise in Typgenehmigungs- und Kundenprozessen, kostenintensive Nachentwicklungen und Rückrufe.

2.1.4 Automotive SPICE 4.1



Kernfokus: Bewertung und Verbesserung der Entwicklungsprozesse für softwarebasierte und elektronische Fahrzeugsysteme.

Bedeutung: Automotive SPICE definiert ein Prozessreferenzmodell und ein Prozessbewertungsmodell. Die Prozessfähigkeit wird anhand festgelegter Fähigkeitsstufen beurteilt. Im Mittelpunkt stehen Anforderungsanalyse, Architektur, Implementierung, Verifikation, Projektmanagement, Konfigurations- und Änderungsmanagement sowie Rückverfolgbarkeit.

Maßgeblich sind die projektspezifisch vereinbarte Modellversion und der Assessment-Umfang.

Konkretes Risiko bei Verletzung: Unzureichend beherrschte Prozesse können widersprüchliche Anforderungen, fehlende Rückverfolgbarkeit, unentdeckte Entwicklungsfehler und mangelhafte Verifikation verursachen. Zusätzlich drohen schlechte Assessment-Ergebnisse, Kundenescalationen, verzögerte Freigaben, kostenintensive Nacharbeiten und der Verlust von Entwicklungsaufträgen.

2.1.5 VDA 6.3:2023 – Prozessaudits



Kernfokus: Bewertung der Qualitätsfähigkeit von Produktentstehungs- und Produktionsprozessen in der automobilen Lieferkette.

Bedeutung: VDA 6.3 stellt ein strukturiertes Verfahren für Potenzialanalysen und Prozessaudits bereit. Es betrachtet Projektmanagement, Produkt- und Prozessentwicklung, Lieferantenmanagement, Serienproduktion und Kundenbetreuung. Ziel ist, Prozessrisiken frühzeitig zu erkennen und die Wirksamkeit festgelegter Maßnahmen zu bewerten.

Konkretes Risiko bei Verletzung: Nicht beherrschte Prozesse können Qualitätsmängel, instabile Produktion, Lieferausfälle und fehlerhafte Produkte verursachen. Eine schlechte Auditbewertung kann Nachaudits, Kundenescalationen, Sondermaßnahmen, Lieferantensperren, die Nichtvergabe neuer Aufträge sowie Nacharbeits-, Gewährleistungs- und Rückrufkosten nach sich ziehen.

2.1.6 VDA 6.8:2024 – Prozessaudit Supply Chain



Kernfokus: Bewertung, Absicherung und kontinuierliche Verbesserung logistischer Prozesse entlang der automobilen Lieferkette.

Bedeutung: VDA 6.8 schafft ein einheitliches Auditverfahren für Projektmanagement, Lieferanten- und Dienstleistungsmanagement, Beschaffungs-, Transport- und Inhouse-Logistik sowie Kundenmanagement. Es unterstützt die systematische Erkennung von Versorgungsrisiken, Schnittstellenproblemen und Schwachstellen im Material- und Informationsfluss.

Konkretes Risiko bei Verletzung: Unzureichend gesteuerte Lieferketten können Fehlteile, Falschlieferungen, Bestandsabweichungen, Rückverfolgbarkeitslücken und Produktionsstillstände verursachen. Weitere Folgen sind Sonderfahrten, hohe Lager- und Logistikkosten,

Kunden eskalationen, gegebenenfalls vertraglich vereinbarte Vertragsstrafen, schlechte Lieferantenbewertungen und der Verlust von Folgeaufträgen.

2.1.7 APQP – Advanced Product Quality Planning



Kernfokus: Vorausplanung und Absicherung der Produkt- und Prozessqualität von der Konzeptphase bis zur stabilen Serienproduktion.

Bedeutung: APQP koordiniert die Qualitätsplanung funktionsübergreifend und verbindet Kundenanforderungen, Terminplanung, Produkt- und Prozessentwicklung, Risikoanalysen, Validierung und Freigabeaktivitäten. Die dritte AIAG-Ausgabe ergänzt Beschaffung, Änderungsmanagement, Programmkennczahlen, Risikominderungspläne und Entscheidungsmeilensteine. Der Control Plan wird in einem separaten Handbuch behandelt und bleibt Bestandteil der abgestimmten Qualitätsplanung.

Konkretes Risiko bei Verletzung: Unzureichende Qualitätsvorausplanung kann dazu führen, dass Anforderungen, Risiken oder Herstellbarkeitsprobleme erst kurz vor Produktionsstart erkannt werden. Mögliche Folgen sind eine verweigerte PPAP- beziehungsweise PPF-Freigabe, Terminverzug, Anlaufprobleme, Ausschuss, Nacharbeit, Feldfehler, Gewährleistungskosten, Rückrufe und der Verlust des Kundenvertrauens.

2.2 Luft- und Raumfahrt

2.2.1 AS9100D / IAQG 9100:2016



Kernfokus: Die AS9100 enthält alle Anforderungen der ISO 9001:2015 sowie zusätzliche Anforderungen an Qualitätsmanagementsysteme für Luftfahrt, Raumfahrt und Verteidigung. Besondere Schwerpunkte sind Produktsicherheit, Konfigurationsmanagement, Risikomanagement, Rückverfolgbarkeit und die Vermeidung gefälschter Bauteile.

Bedeutung: Für elektronische Luftfahrtkomponenten müssen Entwicklungsstände, Stücklisten, Seriennummern, Prüfungen, Freigaben und Änderungen eindeutig dokumentiert und rückverfolgbar sein.

Konkretes Risiko bei Verletzung: Kann die Konfiguration eines ausgelieferten Luftfahrtprodukts nicht eindeutig nachgewiesen werden, kann der Kunde die Lieferung sperren oder zurückweisen. Zusätzlich drohen Zertifizierungsabweichungen und der Verlust von Luftfahrtaufträgen.

2.2.2 ARP4754A



Kernfokus: Systematische Entwicklung ziviler Luftfahrzeuge und komplexer Bordsysteme. ARP4754A behandelt Development Assurance, Funktions- und Anforderungszuordnung, Systemarchitektur, Integration, Validierung, Verifikation und die Abstimmung mit Sicherheitsanalysen.

Bedeutung: Das Regelwerk verbindet die Sicherheitsziele des Gesamtflugzeugs mit der Entwicklung von Systemen, Hardware und Software. Es bildet damit eine wichtige Verbindung zu DO-178C und DO-254 und bestimmt den erforderlichen Entwicklungs- und Nachweisaufwand anhand der Kritikalität.

Konkretes Risiko bei Verletzung: Fehlerhafte Funktionszuordnungen, unvollständige Anforderungen, eine falsche Einstufung des Development Assurance Levels oder fehlende Nachweise können sicherheitskritische Systemwechselwirkungen unentdeckt lassen. Wenn ARP4754A als Nachweisverfahren mit der Zulassungsbehörde vereinbart oder vertraglich vereinbart ist, drohen die Zurückweisung von Nachweisen, Redesigns, Wiederholungsprüfungen, Zulassungsverzögerungen, Mehrkosten und Auftragsverluste.

Standhinweis: Die FAA erkennt ARP4754A über die aktive AC 20-174 als akzeptable Methode für Development Assurance an. SAE hat im Dezember 2023 die Nachfolgeausgabe

ARP4754B veröffentlicht. Die anzuwendende Ausgabe ist projekt- und zulassungsbezogen abzustimmen.

2.2.3 DO-178C



Kernfokus: Die DO-178C beschreibt die Anforderungen an die Entwicklung und Verifikation luftfahrtbezogener Software. Wesentlich sind die vollständige Rückverfolgbarkeit von Anforderungen, Softwaredesign, Quellcode und Tests sowie ein kontrolliertes Konfigurations- und Qualitätsmanagement.

Bedeutung: Agile Softwareentwicklung muss so in den Entwicklungsprozess eingebunden werden, dass alle sicherheitsrelevanten Anforderungen, Änderungen, Tests und Freigaben nachvollziehbar dokumentiert sind.

Konkretes Risiko bei Verletzung: Fehlen Traceability- oder Testnachweise, kann die Softwarezulassung verweigert oder verzögert werden. Dies kann umfangreiche Nacharbeiten, Projektverzögerungen und zusätzliche Kosten verursachen.

2.2.4 DO-254



Kernfokus: Die DO-254 betrifft die Entwicklung komplexer elektronischer Hardware für Luftfahrtsysteme, insbesondere FPGAs, Application-Specific Integrated Circuits (ASICs), Programmable Logic Devices (PLDs) und vergleichbare programmierbare Hardware.

Bedeutung: Bei der Entwicklung eigener Luftfahrtelektronik müssen Hardwareanforderungen, Architektur, Umsetzung, Verifikation, Konfiguration und Freigabe vollständig dokumentiert werden.

Konkretes Risiko bei Verletzung: Wird eine sicherheitskritische Hardwarefunktion nicht ausreichend verifiziert, kann der Zulassungsnachweis abgelehnt werden. Daraus können Redesigns, erneute Prüfungen und erhebliche Terminverzögerungen entstehen.

2.2.5 EASA Part-145



Kernfokus: Genehmigung und Überwachung von Organisationen, die Luftfahrzeuge und Luftfahrtkomponenten instand halten.

Bedeutung: EASA Part-145 enthält Anforderungen an Organisation, Personal, Betriebsstätten, Werkzeuge, Instandhaltungsdaten, Freigabeverfahren, Sicherheitsmanagement und Dokumentation. Ziel ist die sichere und regelkonforme Durchführung sowie Freigabe von Instandhaltungsarbeiten.

Konkretes Risiko bei Verletzung: Fehlerhafte oder unvollständig dokumentierte Instandhaltung kann die Lufttüchtigkeit gefährden. Mögliche Folgen sind Beanstandungen, eingeschränkte oder entzogene Genehmigungen, verweigte Freigaben, Betriebsunterbrechungen, Flugausfälle sowie zivil-, aufsichts- oder strafrechtliche Konsequenzen.

2.2.6 Nadcap



Kernfokus: Branchenweit anerkannte Akkreditierung kritischer Sonderprozesse in der Luftfahrt-, Raumfahrt- und Verteidigungsindustrie.

Bedeutung: Nadcap bewertet unter anderem Wärmebehandlung, chemische Prozesse, zerstörungsfreie Prüfung, Schweißen, Beschichtungen, Werkstoffprüfung und Elektronikfertigung. Die Audits prüfen die Einhaltung technischer Branchenanforderungen und kundenspezifischer Vorgaben.

Konkretes Risiko bei Verletzung: Nichtkonforme Sonderprozesse können unentdeckte Material- oder Bauteilfehler verursachen. Zusätzlich drohen die Nichtvergabe, Aussetzung oder Entziehung der Akkreditierung, der Ausschluss aus freigegebenen Lieferantenlisten, Auftragsverluste, Wiederholungsaudits, Nacharbeit und Produktionsunterbrechungen.

2.3 Militär und Verteidigung

2.3.1 MIL-STD-882E



Kernfokus: Systematische Identifikation, Bewertung und Reduzierung von Gefährdungen militärischer Systeme über den gesamten Lebenszyklus.

Bedeutung: Anwendung bei vertraglicher oder programmbezogener Vorgabe auf sicherheitsrelevante elektronische und programmierbare Systeme in US-Verteidigungsprojekten, einschließlich Safety Plan, Gefährdungsanalysen, Sicherheitsanforderungen, Verifikation und formeller Restrisikoakzeptanz.

Konkretes Risiko bei Verletzung: Unzureichend beherrschte Gefährdungen können zur Ablehnung der Systemfreigabe, zu Vertragsverletzungen, Redesigns, Lieferverzug sowie zu Personen- und Sachschäden führen.

2.3.2 DFARS



Kernfokus: DFARS enthält vertragliche und rechtliche Anforderungen für Lieferanten des US-Verteidigungsministeriums. Dazu gehören unter anderem Cybersicherheit, Schutz kontrollierter Informationen, Materialherkunft, Specialty Metals, Lieferantennachweise und die Vermeidung gefälschter Bauteile.

Bedeutung: Bei Verteidigungsaufträgen müssen die jeweils vertraglich vereinbarten DFARS-Klauseln geprüft und in Einkauf, IT, Fertigung, Dokumentation und Lieferantensteuerung umgesetzt werden.

Konkretes Risiko bei Verletzung: Fehlende Herkunftsnachweise oder unzulässige Materialien können zur Zurückweisung der Lieferung, zu Zahlungsstopps, Vertragsstrafen oder zum Verlust des Verteidigungsauftrags führen.

2.4 Industrie und Maschinensicherheit

2.4.1 IEC 61508



Kernfokus: Die IEC 61508 ist eine branchenübergreifende Grundnorm für die funktionale Sicherheit elektrischer, elektronischer und programmierbarer elektronischer Systeme. Sie regelt den Sicherheitslebenszyklus und die Festlegung von Safety Integrity Levels.

Bedeutung: Die Norm ist insbesondere für industrielle Steuerungen, Sicherheitsfunktionen und branchenübergreifend eingesetzte Elektronikplattformen relevant.

Konkretes Risiko bei Verletzung: Wird für eine Sicherheitsfunktion ein unzureichender SIL festgelegt oder die Ausfallwahrscheinlichkeit nicht nachgewiesen, kann die Funktion im Gefahrenfall versagen. Mögliche Folgen sind Personenschäden, Anlagenstillstände und Haftungsansprüche.

2.4.2 Maschinenrichtlinie 2006/42/EG



Kernfokus: Die Maschinenrichtlinie regelt die Sicherheit von Maschinen, Sicherheitsbauteilen und unvollständigen Maschinen beim erstmaligen Inverkehrbringen oder bei der Inbetriebnahme im Europäischen Wirtschaftsraum. Im Mittelpunkt stehen die Risikobeurteilung, die grundlegenden Sicherheits- und Gesundheitsschutzanforderungen und der Nachweis der Produktkonformität.

Bedeutung: Die Richtlinie ist relevant, soweit das Unternehmen vollständige Maschinen, Sicherheitsbauteile oder unvollständige Maschinen entwickelt und diese Produkte in Verkehr bringt. Für Maschinensteuerungen ist der konkrete Anwendungsbereich anhand ihrer Funktion und Produktart zu prüfen.

Konkretes Risiko bei Verletzung: Wird beispielsweise eine Maschinensteuerung ohne ausreichende Risikobeurteilung oder mit einer unzureichend ausgelegten Sicherheitsfunktion in Verkehr gebracht, kann es zu Fehlfunktionen und Personenschäden kommen. Mögliche Folgen sind ein Vertriebsverbot, behördlich angeordnete Rückrufe, die Korrektur oder Entfernung einer unzulässigen CE-Kennzeichnung, Schadensersatzansprüche und strafrechtliche Konsequenzen.

2.4.3 Maschinenverordnung (EU) 2023/1230



Kernfokus: Die Maschinenverordnung regelt die Sicherheit von Maschinen und dazugehörigen Produkten sowie deren einheitliche Konformitätsbewertung im europäischen Binnenmarkt. Im Mittelpunkt stehen die Risikobeurteilung, die grundlegenden Sicherheits- und Gesundheitsschutzanforderungen und der Nachweis der Produktkonformität. Sie löst die Maschinenrichtlinie 2006/42/EG ab dem 20. Januar 2027 ab.

Bedeutung: Die Verordnung ist ab dem 20. Januar 2027 auf neu in Verkehr gebrachte Maschinen anzuwenden. Sie berücksichtigt unter anderem sicherheitsbezogene Funktionen mit künstlicher Intelligenz, den Schutz sicherheitsrelevanter Steuerungen und Softwaredaten vor Manipulationen sowie besondere Verfahren für bestimmte Maschinenkategorien mit erhöhtem Risiko.

Konkretes Risiko bei Verletzung: Eine unvollständige Risikobeurteilung oder fehlerhafte Konformitätsbewertung kann dazu führen, dass die Maschine nicht in Verkehr gebracht oder in Betrieb genommen werden darf. Darüber hinaus drohen behördliche Stilllegung, Vertriebsverbote, Rückrufe, Nachrüstungen, Bußgelder sowie zivil- und gegebenenfalls strafrechtliche Folgen bei Personen- oder Sachschäden.

2.5 Umweltmanagement und Stoffrecht

2.5.1 ISO 14001:2026



Kernfokus: Die ISO 14001 regelt den Aufbau eines Umweltmanagementsystems. Unternehmen müssen relevante Umweltaspekte, rechtliche Verpflichtungen, Umweltziele, Risiken und Notfallmaßnahmen systematisch steuern.

Bedeutung: Zu berücksichtigen sind insbesondere Energieverbrauch, Gefahrstoffe, Elektronikabfälle, Emissionen, Verpackungen, Entsorgung und umweltbezogene Anforderungen an Lieferanten.

Konkretes Risiko bei Verletzung: Verstöße gegen Umweltrecht, etwa beim Umgang mit Gefahrstoffen oder Abfällen, können Umweltschäden, behördliche Maßnahmen, Bußgelder und Sanierungskosten verursachen. Eine Nichtkonformität mit ISO 14001 kann zu Zertifizierungsabweichungen oder zum Verlust der Zertifizierung führen; die Norm selbst ist kein Gesetz.

2.5.2 REACH (EG) Nr. 1907/2006



Kernfokus: Registrierung, Bewertung, Zulassung und Beschränkung chemischer Stoffe zum Schutz von Gesundheit und Umwelt.

Bedeutung: REACH verpflichtet Unternehmen, Informationen über verwendete oder in Verkehr gebrachte Stoffe zu erheben und deren Risiken zu beherrschen. Für Produkthersteller sind insbesondere Stoffbeschränkungen, Zulassungspflichten, besonders besorgniserregende Stoffe sowie die Informationspflichten innerhalb der Lieferkette relevant.

Konkretes Risiko bei Verletzung: Nicht registrierte, unzulässige oder beschränkte Stoffe können zu einem Vermarktungs- oder Verwendungsverbot führen. Weitere mögliche Folgen sind Lieferstopps, Produktrücknahmen, behördliche Anordnungen, Bußgelder, Haftungsansprüche und kostspielige Materialänderungen während der Serienproduktion.

2.5.3 RoHS-Richtlinie 2011/65/EU



Kernfokus: Beschränkung gefährlicher Stoffe in Elektro- und Elektronikgeräten.

Bedeutung: RoHS begrenzt die Verwendung von zehn gefährlichen Stoffen beziehungsweise Stoffgruppen, darunter Blei, Cadmium, Quecksilber, sechswertiges Chrom, bestimmte bromierte Flammschutzmittel und Phthalate. Die Einhaltung muss durch geeignete Lieferantennachweise, Materialdeklarationen, Prüfungen und die technische Dokumentation belegt werden.

Konkretes Risiko bei Verletzung: Bei Überschreitung der zulässigen Grenzwerte darf das betroffene Produkt grundsätzlich nicht rechtskonform auf dem europäischen Markt bereitgestellt werden. Es drohen Vertriebsverbote, Rücknahmen, Rückrufe, Bußgelder, der Austausch nicht konformer Bauteile sowie eine Korrektur der EU-Konformitätserklärung und der CE-Kennzeichnung.

2.6 EU-Produktrecht und Produkthaftung

2.6.1 GPSR (EU) 2023/988



Kernfokus: Sicherheit von Verbraucherprodukten einschließlich online und im Fernabsatz angebotener Produkte.

Bedeutung: Die GPSR verlangt unter anderem eine interne Risikoanalyse, eine angemessene technische Dokumentation, eindeutige Produkt- und Herstellerangaben, verständliche Sicherheitsinformationen und wirksame Prozesse für Beschwerden, Sicherheitsvorfälle und Rückrufe. Sie greift insbesondere dort, wo spezielle europäische Produktvorschriften ein Risiko nicht vollständig abdecken.

Konkretes Risiko bei Verletzung: Ein unsicheres oder unzureichend dokumentiertes Produkt kann von den Marktüberwachungsbehörden beanstandet oder vom Markt genommen werden. Mögliche Folgen sind Verkaufsverbote, Rücknahmen, öffentliche Rückrufe, Meldungen über das Safety-Gate-System, Bußgelder, Schadensersatzansprüche und erhebliche Reputationsschäden.

2.6.2 Weitere EU-Produktvorschriften



Kernfokus: Neben produktspezifischen Harmonisierungsrechtsvorschriften sind je nach Produkt unter anderem Marktüberwachung, allgemeine Produktsicherheit, Cybersecurity, Stoffrecht und Produkthaftung zu prüfen.

Bedeutung: Die Pflichten reichen von Konstruktion und Fertigung über Inverkehrbringen und Marktbeobachtung bis zu Korrekturmaßnahmen, Rücknahmen, Rückrufen und Entsorgung. Die Richtlinie (EU) 2024/2853 modernisiert die Produkthaftung insbesondere für Software, digitale Funktionen und Aktualisierungen.

Konkretes Risiko bei Verletzung: Unklare Verantwortlichkeiten und unvollständige Nachweise erhöhen das Risiko behördlicher Maßnahmen, Rückrufe, Haftungsfälle und Reputationsschäden.

2.7 Branchenübergreifendes Management und Prüfkompentenz

ISO 9001 bildet die Grundlage für gemeinsame Qualitätsmanagementprozesse; ISO 31000 liefert branchenübergreifende Leitlinien zum Risikomanagement. Ihre integrierte Anwendung wird in den folgenden Kapiteln erläutert. ISO/IEC 17025 ergänzt diese Grundlagen um die nachgewiesene Kompetenz von Prüf- und Kalibrierlaboratorien.

2.7.1 ISO/IEC 17025:2017



Kernfokus: Kompetenz, Unparteilichkeit und einheitliche Arbeitsweise von Prüf- und Kalibrierlaboratorien.

Bedeutung: Die Norm legt Anforderungen an Personal, Prüf- und Kalibrierverfahren, Geräte, Messrückführbarkeit, Ergebnisvalidierung und Berichterstattung fest. Sie schafft Vertrauen in die fachliche Richtigkeit und Vergleichbarkeit von Laborergebnissen.

Konkretes Risiko bei Verletzung: Fehlerhafte oder nicht rückführbare Ergebnisse können zu falschen Produktfreigaben und Sicherheitsentscheidungen führen. Zusätzlich drohen die Zurückweisung von Prüfberichten, Wiederholungsprüfungen, Kundenverluste sowie die Einschränkung, Aussetzung oder Entziehung der Akkreditierung.

3 Integrierte Umsetzung der Regelwerke

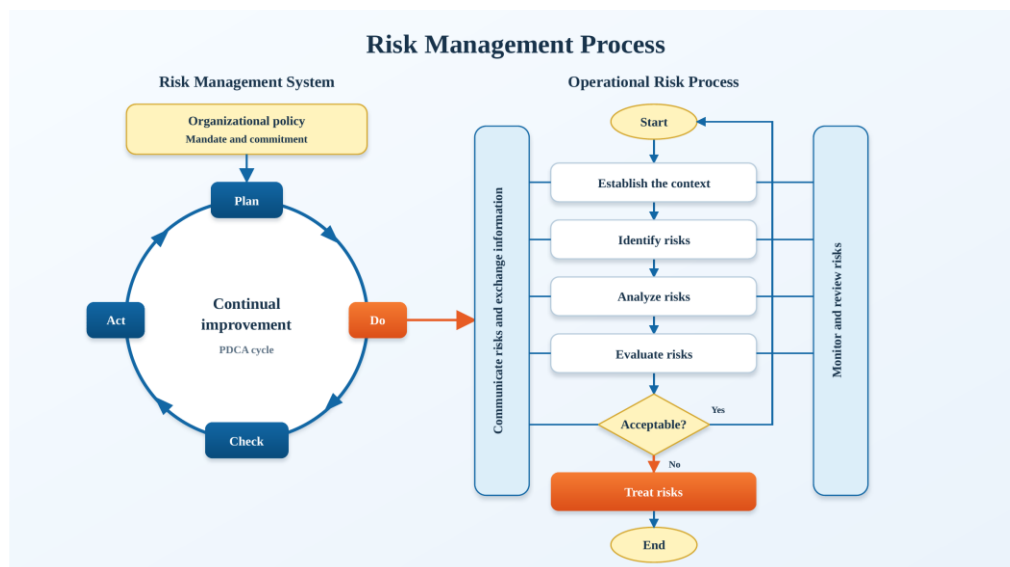
Diese Regelwerke sollten nicht isoliert in getrennten Managementsystemen umgesetzt werden. Unternehmen sollten gemeinsame Kernprozesse für Dokumentenlenkung, Risiko- und Änderungsmanagement, Lieferantensteuerung, Kompetenzmanagement, interne Audits und Managementbewertung verwenden. Regelwerksspezifisch bleiben dagegen Verantwortlichkeiten, Akzeptanzkriterien und Nachweise. Dadurch entsteht ein integriertes System.

Für Automotive-Projekte lassen sich Automotive SPICE, APQP sowie VDA 6.3 und VDA 6.8 durch gemeinsame Anforderungs-, Änderungs-, Lieferanten- und Freigabeprozesse verbinden. Im Luftfahrtbereich stellt ARP4754A die Verbindung zur Systementwicklung her. Eine Zuordnungsmatrix sollte je Anforderung das Regelwerk, die anwendbare Ausgabe, die verantwortliche Rolle und den erforderlichen Nachweis benennen.

4 Der risikobasierte Ansatz

Ein risikobasierter Ansatz ermöglicht Abweichungen frühzeitig zu erkennen, zu bewerten und mit angemessenen Kontrollen zu verhindern. Risiken werden deshalb bereits bei Planung, Entwicklung, Beschaffung, Fertigung, Lieferung und Änderung berücksichtigt und nicht erst nach Eintritt eines Fehlers behandelt.

Die Grundlage hierfür ist die DIN EN ISO 9001:2015-11, Abschnitt 6.1 „Maßnahmen zum Umgang mit Risiken und Chancen“. Die ISO 9001 verbindet den Prozessansatz ausdrücklich mit dem Plan-Do-Check-Act-Zyklus (PDCA) und risikobasiertem Denken. Ergänzend dazu gibt es die DIN ISO 31000:2018-10 „Risikomanagement - Leitlinien“.



Der Risikomanagement-Prozess beim risikobasierten Ansatz²

Welche Bewertungskriterien anzuwenden sind, hängt vom jeweiligen Regelwerk ab. Bei Qualitätsrisiken stehen häufig Auftreten, Bedeutung und Entdeckung im Vordergrund. Bei funktionaler Sicherheit kommen Kriterien wie Exposition, Beherrschbarkeit, Sicherheitsintegrität und zulässiges Restrisiko hinzu. Bei gesetzlichen und vertraglichen Verpflichtungen ist zusätzlich zu prüfen, ob eine Abweichung überhaupt zulässig ist.

²Quelle der Grundstruktur: Brühwiler, Bruno (2007): Risikomanagement als Führungsaufgabe. Haupt Verlag, Bern/Stuttgart/Wien. Die Darstellung wurde nachträglich um Elemente der erstmals 2009 veröffentlichten ISO 31000 und der DIN ISO 31000:2018-10 ergänzt.

4.1 Qualitäts- und Prozessanforderungen

Die IATF 16949 und AS9100 nutzen Risiken hauptsächlich zur Priorisierung von Qualitäts-, Prozess- und Lieferantenmaßnahmen. Nicht jeder Prozess wird mit gleicher Intensität überwacht. Prozesse mit hohen Auswirkungen auf Produktsicherheit, Lieferfähigkeit oder Kundenzufriedenheit erhalten strengere Kontrollen.

Bei der IATF 16949 werden Produkt-, Prozess-, Lieferanten- und Kundenrisiken präventiv durch APQP, FMEA, Produktionslenkungspläne, SPC, MSA und Notfallplanung bewertet und beherrscht. Die 8D-Methode dient der strukturierten Bearbeitung bereits aufgetretener Probleme. Ein begrenztes Qualitätsrestrisiko kann akzeptiert werden, wenn Kunden-, Produkt- und Sicherheitsanforderungen weiterhin erfüllt sind und die Entscheidung dokumentiert ist. Kritische Merkmale und Prozesse erhalten strengere Kontrollen.

Bei der **AS9100** stehen insbesondere Produktsicherheit, Konfiguration, Lieferanten, gefälschte Bauteile, Termin- und Qualitätsleistung im Fokus. Änderungen erfordern intensivere Prüfungen und Freigaben. Die Restrisiken müssen dokumentiert, überwacht und bei sicherheitsrelevanten Auswirkungen mit Kunden und den Luftfahrtbehörden abgestimmt werden.

Automotive SPICE richtet die Prozessverbesserung auf nachgewiesene Prozessfähigkeit aus. VDA 6.3 bewertet Risiken in Produktentstehung und Produktion, VDA 6.8 in der Logistik. APQP verbindet die frühzeitige Risikoanalyse mit abgestimmten Maßnahmen und Freigabemeilensteinen. Assessment, Prozessaudit und Qualitätsvorausplanung ergänzen sich, ersetzen aber keine produktspezifischen Sicherheitsnachweise.

ISO/IEC 17025 überträgt den risikobasierten Ansatz auf die Gültigkeit von Prüf- und Kalibrierergebnissen. Nadcap konzentriert ihn auf die Beherrschung kritischer Sonderprozesse. In beiden Fällen sind kompetentes Personal, geeignete Verfahren, nachvollziehbare Aufzeichnungen und wirksame Korrekturmaßnahmen entscheidend.

4.2 Sicherheitsstandards und Development Assurance

Diese richten den Entwicklungs- und Nachweisaufwand nach der möglichen Sicherheitsauswirkung eines Fehlers aus. Je höher die Kritikalität, desto strenger sind Entwicklung, Verifikation, Unabhängigkeit, Dokumentation und Freigabe. Ein Restrisiko darf nur akzeptiert werden, wenn die vorgeschriebenen Sicherheitsmaßnahmen und Nachweise vollständig umgesetzt wurden.

ARP4754A verknüpft die Sicherheitsziele auf Flugzeug- und Systemebene mit Anforderungszuordnung, Architektur und Development Assurance. Die Nachweise für Software nach DO-178C und Hardware nach DO-254 werden darauf abgestimmt; die Standards sind nicht untereinander austauschbar.

Der notwendige Entwicklungs- und Verifikationsaufwand richtet sich nach den Anforderungen an die funktionale Sicherheit. Mit zunehmender Kritikalität steigen die Anforderungen an Traceability, Tests, Reviews und unabhängige Verifikations-, Validierungs- oder Bestätigungsmaßnahmen.

Regelwerk	Bezeichnung der Sicherheits-/Einstufungsstufen	Stufen von niedrig nach hoch
DO-178C / DO-254	Design Assurance Level (DAL)	DAL E → DAL D → DAL C → DAL B → DAL A
ISO 26262	Automotive Safety Integrity Level (ASIL)	„QM“ → ASIL A → ASIL B → ASIL C → ASIL D
IEC 61508	Safety Integrity Level (SIL)	SIL 1 → SIL 2 → SIL 3 → SIL 4
MIL-STD-882E	Risikostufe aus Schweregrad und Eintrittswahrscheinlichkeit	Low → Medium → Serious → High
Maschinenrichtlinie 2006/42/EG / Maschinenverordnung (EU) 2023/1230	Keine eigenen Sicherheitslevel; Einstufung sicherheitsbezogener Steuerungen nach EN ISO 13849-1 oder IEC 62061	PL a → PL b → PL c → PL d → PL e bzw. SIL 1 → SIL 2 → SIL 3
ARP4754A	Functional Development Assurance Level (FDAL) und Item Development Assurance Level (IDAL)	E → D → C → B → A

Tabelle: Abstufungen der Sicherheitsstandards

Hinweise

- DAL, ASIL, SIL, PL und militärische Risikokategorien können nicht unmittelbar zueinander gleichgesetzt werden.
- Mit „QM“ werden bei der Anwendung der ISO 26262 die Bereiche bezeichnet, die nicht einen ASIL-Level unterliegen aber den Anforderungen eines Qualitätsmanagementsystems entsprechen müssen.

Folgen bei der Nichtbeachtung von Sicherheitsstandards entstehen, weil sie als vertragliche Anforderungen, Zulassungsgrundlage, anerkannter Stand der Technik oder Nachweis einer ordnungsgemäßen Entwicklung herangezogen werden. Verursacht ein fehlerhaftes Produkt einen Personen- oder Sachschaden, kann der Hersteller nach dem Produkthaftungsgesetz haften.

Werden erkennbare Sicherheitsrisiken fahrlässig ignoriert und dadurch Menschen verletzt oder getötet, kann gegen verantwortliche Personen wegen fahrlässiger Körperverletzung oder fahrlässiger Tötung ermittelt werden.

4.3 Rechtlich oder vertraglich verbindliche Compliance-Vorgaben

Die DFARS, EASA Part-145, die im Umweltmanagement zu berücksichtigenden umweltrechtlichen Verpflichtungen, die Maschinenrichtlinie und die EU-Produktvorschriften lassen keinen beliebigen Risikoausgleich zu. Eine niedrige Eintrittswahrscheinlichkeit oder hohe Umsetzungskosten berechtigen nicht dazu, eine verbindliche Vorschrift unbeachtet zu lassen. Nadcap-Anforderungen sind zusätzlich verbindlich, soweit sie vertraglich oder durch Kundenvorgaben vereinbart sind. Die Risikobewertung bestimmt hier die erforderlichen Kontrollen, nicht aber, ob die Verpflichtung erfüllt werden muss.

4.4 Der Unterschied zwischen Qualitäts-, Sicherheits- und Compliance-Risiken

Die Risikobewertung beantwortet drei unterschiedliche Fragen:

In einer Qualitätsnorm:

- Welche Risiken sind wichtig und wie intensiv müssen sie behandelt werden?
- Die Qualitätsrisiken werden nach ihrer Bedeutung priorisiert.

In einer Sicherheitsnorm:

- Welche technischen Maßnahmen sind notwendig, um das Restrisiko auf ein erträgliches Level zu begrenzen?
- Definition der formalen Beherrschung des Risikos und Festlegung des notwendigen Sicherheits- und Nachweisaufwands.
- Sicherheitsrisiken müssen bis zu einem nachweisbar vertretbaren Restrisiko reduziert werden.

In einer rechtlichen oder vertraglichen Compliance-Vorgabe:

- Welche Kontrollen sind erforderlich, damit ein Verstoß gegen verbindliche Vorgaben zuverlässig verhindert wird?
- Gesetzliche und vertragliche Verpflichtungen müssen unabhängig von Eintrittswahrscheinlichkeit, Kosten oder wirtschaftlichem Nutzen eingehalten werden.

4.5 Beispiel für ein Elektronikunternehmen

Das Unternehmen entwickelt einen Inverter, der in einem Nutzfahrzeug, einer Industriemaschine und einer militärischen Anwendung eingesetzt werden soll.

- Nach der IATF 16949 wird das Risiko fehlerhafter Lötstellen oder schwankender Fertigungsprozesse durch FMEA, SPC, MSA und einen Produktionslenkungsplan behandelt.

- Nach ISO 26262 wird geprüft, ob eine Fehlfunktion zu einer Gefährdung führen kann. Aus Schwere, Exposition und Beherrschbarkeit wird der benötigte ASIL abgeleitet.
- Nach IEC 61508 wird für die industrielle Sicherheitsfunktion der erforderliche SIL bestimmt und die notwendige Risikominderung nachgewiesen.
- Bei einer militärischen Verwendung wird nach MIL-STD-882E eine Gefährdungsanalyse durchgeführt und das verbleibende Risiko durch die zuständige Stelle akzeptiert.
- Nach DFARS wird zusätzlich geprüft, ob die vertraglichen Vorgaben zu Materialherkunft, Cybersecurity, Controlled Unclassified Information (CUI) und Unterauftragnehmern erfüllt sind.
- Bei einem Inverkehrbringen auf dem europäischen Markt müssen schließlich die anwendbaren EU-Produktvorschriften und bis zum 19. Januar 2027 die Maschinenrichtlinie erfüllt werden; ab dem 20. Januar 2027 gilt die Maschinenverordnung.

4.6 Resümee

Für Unternehmen, die in mehreren hoch regulierten Bereichen tätig sind, ist ein integriertes Qualitäts-, Sicherheits- und Compliance-Management-System sinnvoll. Gemeinsame Prozesse wie Risikomanagement, Dokumentenlenkung, Konfigurationsmanagement, Änderungsweisen, Lieferantensteuerung, Verifikation und Auditierung sollten einheitlich organisiert werden. Die jeweiligen branchenspezifischen Nachweise müssen jedoch weiterhin getrennt und eindeutig nachvollziehbar bleiben.

5 Quellen und Aktualitätsstand

Die folgende Auswahl verweist auf die für den Veröffentlichungsstand maßgeblichen offiziellen Informationsquellen. Die vollständigen Normtexte sind in der jeweils gültigen Ausgabe über die zuständigen Herausgeber zu beziehen.

Regelwerk	Stand am 6. September 2026	Offizielle Quelle
AIAG APQP, 3. Ausgabe	Qualitätsvorausplanung; 2024. Control Plan als separates Handbuch	AIAG
ARP4754A / FAA AC 20-174	Ausgabe A von 2010; durch aktive FAA AC 20-174 anerkannt. Projektbezogene Anwendbarkeit prüfen	FAA
ARP4754B	SAE-Nachfolgeausgabe von Dezember 2023; nicht automatisch Ersatz der vereinbarten Ausgabe A	SAE
Automotive SPICE 4.1	Prozessreferenz- und Prozessbewertungsmodell; August 2026	VDA QMC
DFARS	Fortlaufend aktualisiertes Vertragsregelwerk	Acquisition.gov
DO-178C / DO-254	Veröffentlichte Zulassungsleitlinien	RTCA
EASA Part-145	Aktuelle Anforderungen gemäß Verordnung (EU) Nr. 1321/2014 und EASA Easy Access Rules	EASA
EN ISO 13849-1:2023	Veröffentlichte aktuelle Ausgabe	ISO
GPSR (EU) 2023/988	Seit 13. Dezember 2024 anwendbar	EUR-Lex
IAQG 9100:2016 / AS9100D	Veröffentlichte und weiterhin maßgebliche Ausgabe	IAQG
IATF 16949:2016	Veröffentlichte und weiterhin maßgebliche Ausgabe	IATF
IEC 61508:2010 (Normenreihe)	Zweite Ausgabe; weiterhin veröffentlicht	IEC
IEC 62061:2021 + AMD1:2024 + AMD2:2026	Aktueller konsolidierter Stand	IEC
ISO 14001:2026	Seit April 2026 veröffentlicht; Ausgabe 2015 zurückgezogen	ISO
ISO 26262:2018 (Normenreihe)	Veröffentlichte aktuelle Ausgabe	ISO
ISO 31000:2018	Veröffentlichte aktuelle Ausgabe	ISO
ISO 9001:2015/Amd 1:2024	Gültig; Nachfolgeausgabe ISO 9001 in Veröffentlichung	ISO

Regelwerk	Stand am 6. September 2026	Offizielle Quelle
ISO/IEC 17025:2017	Veröffentlichte aktuelle Ausgabe	ISO
ISO/SAE 21434:2021	Veröffentlichte aktuelle Ausgabe	ISO
Maschinenrichtlinie 2006/42/EG	Anwendbar bis 19. Januar 2027	EUR-Lex
Maschinenverordnung (EU) 2023/1230	Anwendbar ab 20. Januar 2027	EUR-Lex
MIL-STD-882E, Change 1	Aktueller Änderungsstand von 2023	DLA Quick Search
Nadcap	Fortlaufend aktualisiertes Akkreditierungsprogramm für kritische Sonderprozesse	PRI
Produkthaftungsrichtlinie (EU) 2024/2853	Nationale Umsetzung bis 9. Dezember 2026	EUR-Lex
REACH (EG) Nr. 1907/2006	Konsolidierter Stand vom 22. Juni 2026	EUR-Lex
RoHS-Richtlinie 2011/65/EU	In der jeweils geänderten Fassung anzuwenden	EUR-Lex
VDA 6.3:2023	Prozessaudit; 4. Ausgabe, Januar 2023	VDA QMC
VDA 6.8:2024	Prozessaudit Supply Chain; Dezember 2024	VDA

6 Abkürzungsverzeichnis

Abkürzung	Bedeutung
8D	Acht Disziplinen; strukturierte Methode zur Problemlösung und Reklamationsbearbeitung
AC	Advisory Circular; Rundschreiben der FAA mit anerkannten Nachweisverfahren
AIAG	Automotive Industry Action Group; Herausgeber unter anderem des APQP-Handbuchs
AMD	Amendment; Änderung oder Ergänzung einer Norm
APQP	Advanced Product Quality Planning; vorausschauende Produktqualitätsplanung
ARP	Aerospace Recommended Practice; technische Empfehlung von SAE International
ARP4754A	Guidelines for Development of Civil Aircraft and Systems; Leitlinien für die Entwicklung ziviler Luftfahrzeuge und Systeme, Ausgabe A
AS9100D	US-Ausgabe der IAQG-Norm 9100:2016 für Qualitätsmanagement in Luftfahrt, Raumfahrt und Verteidigung
ASAM	Association for Standardization of Automation and Measuring Systems
ASIC	Application-Specific Integrated Circuit; anwendungsspezifische integrierte Schaltung
ASIL	Automotive Safety Integrity Level; Sicherheitsintegritätsstufe nach ISO 26262
ASPICE	Automotive SPICE; Prozessreferenz- und Prozessbewertungsmodell für die automobile Entwicklung
AUTOSAR	AUTomotive Open System ARchitecture; Entwicklungspartnerschaft zur Standardisierung von Softwarearchitekturen für Fahrzeuge
CE	CE-Kennzeichnung; Kennzeichnung der Konformität mit anwendbaren EU-Harmonisierungsrechtsvorschriften
CUI	Controlled Unclassified Information; kontrollierte, nicht als geheim eingestufte Information
DAL	Design Assurance Level; Entwicklungs- und Nachweisstufe nach DO-178C und DO-254
DFARS	Defense Federal Acquisition Regulation Supplement
DIN	Deutsches Institut für Normung e. V.; zugleich Kennzeichnung deutscher Normen
DLA	Defense Logistics Agency
DO-178C	Software Considerations in Airborne Systems and Equipment Certification
DO-254	Design Assurance Guidance for Airborne Electronic Hardware
E/E	Elektrisch/elektronisch

Abkürzung	Bedeutung
EASA	European Union Aviation Safety Agency; Agentur der Europäischen Union für Flugsicherheit
EG	Europäische Gemeinschaft; Bezeichnung in älteren EU-Rechtsakten
EN	Europäische Norm
EU	Europäische Union
FAA	Federal Aviation Administration; US-amerikanische Luftfahrtbehörde
FDAL	Functional Development Assurance Level; Entwicklungsabsicherungsstufe auf Funktionsebene
FMEA	Failure Mode and Effects Analysis; Fehlermöglichkeits- und Einflussanalyse
FPGA	Field-Programmable Gate Array; frei programmierbarer Logikbaustein
GPSR	General Product Safety Regulation; Verordnung (EU) 2023/988
IAQG	International Aerospace Quality Group
IATF	International Automotive Task Force
IDAL	Item Development Assurance Level; Entwicklungsabsicherungsstufe auf Item-Ebene
IEC	International Electrotechnical Commission
ISO	International Organization for Standardization
IT	Informationstechnik; Technologien und Systeme zur elektronischen Verarbeitung, Speicherung und Übertragung von Informationen
MIL-STD	Military Standard; US-Militärstandard
MSA	Measurement System Analysis; Messsystemanalyse
Nadcap	Branchenprogramm zur Akkreditierung kritischer Sonderprozesse in Luftfahrt, Raumfahrt und Verteidigung
OEM	Original Equipment Manufacturer; Erstausrüster
ONR	ON-Regel von Austrian Standards
PAM	Process Assessment Model; Prozessbewertungsmodell
PDCA	Plan - Do - Check - Act
PL	Performance Level nach EN ISO 13849-1
PLD	Programmable Logic Device; programmierbarer Logikbaustein
PPAP	Production Part Approval Process; Produktionsprozess- und Produktfreigabeverfahren
PPF	Produktionsprozess- und Produktfreigabe nach VDA
PRI	Performance Review Institute; Träger des Nadcap-Programms
PRM	Process Reference Model; Prozessreferenzmodell

Abkürzung	Bedeutung
QM	Quality Management; Qualitätsmanagement. In ISO 26262 bezeichnet QM eine Einstufung außerhalb der ASIL-Stufen.
QMC	Qualitätsmanagement Center im VDA
QMS	Quality Management System; Qualitätsmanagementsystem
REACH	Registration, Evaluation, Authorisation and Restriction of Chemicals
RoHS	Restriction of Hazardous Substances
RTCA	Radio Technical Commission for Aeronautics
SAE	SAE International
SIL	Safety Integrity Level; Sicherheitsintegritätsstufe
SPC	Statistical Process Control; statistische Prozessregelung
SPICE	Systems/Software Process Improvement and Capability Determination
V&V	Verification and Validation; Verifikation und Validierung
VDA	Verband der Automobilindustrie

7 Über den Autor

Bernhard Wagner, Diplom-Informatiker und MBA, verfügt über mehr als 25 Jahre Erfahrung in Software, Elektronik, Systems Engineering und Qualitätsmanagement. Seine Schwerpunkte sind Functional Safety nach ISO 26262 und IEC 61508, Automotive SPICE, Fahrzeugdiagnose sowie Konfigurations- und Änderungsmanagement. Er arbeitete unter anderem als Softwareentwickler, Systemarchitekt, Projektleiter und technischer Direktor, wirkte in ASAM- und ISO-Arbeitsgruppen mit und ist Mitautor von ISO 22900-2, ISO 22900-3 und der Diagnose in AUTOSAR.



Heute unterstützt er Unternehmen zudem bei der Qualitätssicherung komplexer Elektroniksysteme und bei der Implementierung normgerechter Entwicklungsprozesse.